11. 정보 보안 기초 (단답형 대비)

> 2급 실기 후기에서 단답형으로 **IPSec(AH·ESP·SA), WAF, 방화벽, SSL, HTTPS, SSH**가 출제된 사례가 확인됩니다. 공식 출제기준 PDF로 범위를 최종 확인하기 전까지는 **단답형 대비용**으로 활용하세요. (→ 00_1급-2급 범위 점검.md 참고)

---

1. 보안의 3요소와 관련 개념

요소	의미	위협 예
기밀성(Confidentiality)	인가된 자만 열람	도청, 스니핑
무결성(Integrity)	변조되지 않음	위·변조
가용성(Availability)	필요할 때 사용 가능	DoS
인증	신원 확인	위장
부인방지	행위를 부인하지 못함	전자서명

AAA

Authentication(인증) · Authorization(인가) · Accounting(과금/감사)

- 프로토콜: **RADIUS**(UDP 1812/1813, 인증+인가 결합) · **TACACS+**(TCP 49, 분리·명령 단위 제어) · **Kerberos**(티켓 기반, 포트 88)
- **802.1X**: 포트 기반 접근 제어(유무선), EAP + RADIUS

접근 통제 모델

모델	설명
DAC	소유자가 권한 결정 (리눅스 chmod)
MAC	시스템 정책(보안 등급)으로 강제 (SELinux)
RBAC	역할 기반

---

2. 암호 기술

구분	특징	알고리즘
대칭키(비밀키)	암·복호화 키 동일, **빠름**, 키 분배 어려움	DES, 3DES, **AES**, SEED, ARIA, RC4
비대칭키(공개키)	키 쌍(공개키/개인키), **느림**, 키 분배 쉬움	**RSA**, ECC, DSA, ElGamal, Diffie-Hellman(키 교환)
해시	단방향, 고정 길이 출력, **무결성**	MD5(128bit), **SHA-1**(160bit), **SHA-256**

- **암호화**: 수신자의 **공개키**로 암호화 → 수신자의 **개인키**로 복호화
- **전자서명**: 송신자의 **개인키**로 서명 → 송신자의 **공개키**로 검증 (무결성 + 인증 + 부인방지)
- **PKI / 인증서(X.509)**: CA가 공개키의 소유자를 보증

- 실제로는 **하이브리드**: 공개키로 대칭키를 교환하고, 데이터는 대칭키로 암호화

---

3. IPSec (자주 출제 ★)

3계층(IP)에서 동작하는 보안 프로토콜 모음. 암호화·인증·무결성을 제공하며 **IPv6에는 기본 포함**됩니다.

구성 요소

요소	IP 프로토콜 번호	기능
AH (Authentication Header)	**51**	**인증 + 무결성** (**암호화는 제공하지 않음**)
ESP (Encapsulating Security Payload)	**50**	**암호화 + (선택) 인증·무결성**
IKE	UDP **500**	키 교환·SA 협상 (NAT 통과 시 UDP 4500)
SA (Security Association)	-	두 단말 간 **보안 협약**(알고리즘·키·수명). **단방향**이라 양방향 통신에는 2개 필요. **SPI**로 식별

동작 모드

모드	설명	용도
Transport	원본 IP 헤더 유지, **페이로드만** 보호	호스트 ↔ 호스트
Tunnel	**원본 IP 패킷 전체**를 보호하고 새 IP 헤더를 붙임	**게이트웨이 ↔ 게이트웨이 (VPN)**

> **AH = 암호화 없음**, **ESP = 암호화 있음** — 가장 자주 나오는 구분입니다.

---

4. SSL/TLS · HTTPS · SSH

항목	내용
SSL/TLS	전송 계층 위에서 동작하는 보안 프로토콜(표현·세션 계층 사이 성격). SSL 3.0 → **TLS 1.0~1.3** (SSL은 취약해 폐기)
HTTPS	HTTP + SSL/TLS, 포트 **443**
핸드셰이크	암호 스위트 협상 → 서버 인증서 제공 → 키 교환 → 이후 **대칭키로 암호화**
SSH	포트 **22**, Telnet을 대체하는 암호화 원격 접속. 포트 포워딩·SFTP·SCP 지원
SFTP vs FTPS	SFTP = SSH 기반(22) / FTPS = FTP + SSL

SSH의 특징 (2026-1회 2번)

특징	설명
암호화	전송 데이터를 **암호화**(기밀성) — Telnet·rlogin·FTP의 평문 전송을 대체
무결성	메시지 인증 코드(MAC)로 **데이터 무결성** 제공
인증	**공개키 암호화 기법** 사용(서버 호스트 키, 사용자 공개키 인증) + 비밀번호 인증도 가능

특징	설명
플랫폼	**리눅스·유닉스·윈도우 등 여러 OS에서 사용 가능** (OpenSSH) — '리눅스/유닉스에서만 사용 가능'은 ✗
포트	**TCP 22**
기능	원격 로그인, 파일 전송(SCP·SFTP), **포트 포워딩(터널링)**
관련 파일	서버 설정 `/etc/ssh/sshd_config`, 사용자 키 `~/.ssh/authorized_keys`, 접속한 서버 기록 `~/.ssh/known_hosts`

---

5. VPN

방식	계층	특징
IPSec VPN	3계층	사이트 간(Site-to-Site)에 많이 사용
SSL VPN	4~7계층	웹 브라우저 기반 원격 접속, 별도 클라이언트 불필요
L2TP	2계층	터널링만 제공 → 보통 **L2TP/IPSec**으로 암호화
PPTP	2계층	구형, 보안 취약
MPLS VPN	2.5계층	사업자 망 기반

---

6. 방화벽 · IDS/IPS · WAF

방화벽 종류

종류	동작 계층	설명
패킷 필터링	3·4	IP·포트로 허용/차단. 빠름, 상태 추적 없음
상태 검사(Stateful)	3·4	연결 상태 테이블 유지
애플리케이션 게이트웨이(프록시)	7	프로토콜 내용까지 검사, 느림
NGFW (차세대 방화벽)	3~7	애플리케이션 식별·IPS·사용자 식별 통합

구분 정리 (출제 단골)

장비	역할
IDS	침입 **탐지** 후 경고 (차단 안 함, 보통 옆에서 감시)
IPS	침입 **탐지 + 차단** (인라인 배치)
WAF (웹 방화벽)	**웹 애플리케이션 계층(7)** 공격(**SQL Injection·XSS** 등) 차단. 일반 방화벽이 못 막는 HTTP 내용 검사
UTM	방화벽·IPS·VPN·안티바이러스 통합 장비
DMZ	외부에 공개하는 서버를 두는 **완충 구간**
프록시	대리 요청, 캐싱, 접근 제어
허니팟	공격자를 유인하는 가짜 시스템

IDS 탐지 방식

- **오용(Misuse/Signature)**: 알려진 패턴과 비교 — 오탐 적음, **신종 공격 탐지 어려움**
- **이상(Anomaly)**: 정상 기준에서 벗어난 행위 탐지 — 신종 공격 탐지 가능, **오탐 많음**
- 배치: **NIDS**(네트워크) / **HIDS**(호스트)

---

7. 공격 유형

서비스 거부(DoS/DDoS)

공격	원리
SYN Flooding	SYN만 대량 전송(3-way 미완료)해 연결 대기 큐 고갈. 대응: SYN Cookie
Smurf	**출발지를 피해자로 위조한 ICMP Echo를 브로드캐스트**해 응답 폭주
Land	**출발지 IP = 목적지 IP**로 위조
Teardrop	단편화 **오프셋을 겹치게** 조작해 재조립 오류 유발
Ping of Death	규격 초과의 거대 ICMP 패킷
UDP Flooding	UDP 패킷 대량 전송
DDoS	좀비 PC(봇넷)를 이용한 분산 공격

도청·위장·탈취

공격	설명
스니핑	패킷 도청 (수동적)
스푸핑	IP·MAC·DNS 등 **주소 위장**. ARP 스푸핑 = ARP 테이블 오염
세션 하이재킹	인증된 세션 탈취
MITM	중간자 공격
포트 스캔	열린 포트 탐색 (nmap)
피싱 / 파밍	가짜 사이트로 정보 탈취 / DNS 변조로 유도

웹·시스템 공격

공격	설명
SQL Injection	입력값에 SQL을 삽입해 DB 조작
XSS	악성 스크립트를 웹 페이지에 삽입해 사용자 브라우저에서 실행
CSRF	사용자가 의도치 않은 요청을 서버에 전송하도록 유도
버퍼 오버플로우	버퍼 초과 입력으로 메모리 덮어쓰기
랜섬웨어	파일 암호화 후 금전 요구

---

8. 무선 보안

WEP(RC4, 취약) → WPA(TKIP) → WPA2(AES-CCMP) → WPA3(SAE)

- SSID 숨김·MAC 필터링만으로는 보안이 불충분
- 엔터프라이즈 모드: **802.1X + RADIUS**

---

9. 마무리 체크 문제

1. 보안의 3요소는? → **기밀성·무결성·가용성**
2. 대칭키와 비대칭키 대표 알고리즘? → **AES / RSA**
3. 전자서명에 쓰는 키는? → **송신자의 개인키로 서명, 송신자의 공개키로 검증**
4. IPSec에서 암호화를 제공하는 것은? → **ESP** (AH는 인증·무결성만)
5. AH와 ESP의 IP 프로토콜 번호? → **51 / 50**
6. SA의 방향성과 식별자? → **단방향, SPI**
7. VPN 게이트웨이 간에 쓰는 IPSec 모드? → **터널 모드**
8. IKE의 포트? → **UDP 500**
9. HTTPS와 SSH의 포트? → **443 / 22**
10. WAF가 막는 공격 유형 2가지? → **SQL Injection, XSS**
11. IDS와 IPS의 차이? → **탐지만 / 탐지+차단**
12. 서명(시그니처) 기반 탐지의 한계? → **신종 공격 탐지 어려움**
13. 출발지를 피해자로 위조한 ICMP 브로드캐스트 공격? → **Smurf**
14. 출발지와 목적지 IP를 같게 만드는 공격? → **Land**
15. SYN Flooding의 대응 기법? → **SYN Cookie**, 백로그 증가, 방화벽 임계값
16. 일반 방화벽과 NGFW의 차이? → **NGFW는 애플리케이션 식별·IPS 등 통합 (3~7계층)**
17. RADIUS의 포트와 용도? → **UDP 1812/1813, 인증·인가·과금**
18. 현재 권장되는 무선 보안 규격? → **WPA2(AES) 이상**